

1. (CP)LC 1 - Intro to SSD

- a. SDLC history & review
 - i. Waterfall vs agile - overview of methodologies
- b. Risk & SDLC
 - i. Adding sec/ review steps to SDLC
- c. Standards around SSD (NIST, OWASP, etc)
- d. Architecture & the SDLC
- e. Course text ch 1 - 3

Formatted: Left: 1.27 cm, Right: 1.27 cm, Top: 1.27 cm, Bottom: 1.27 cm

Commented [PC1]: Does this refer to risks with each of the waterfall and agile approaches? Or to which specific approach?

Commented [PC2]: What does this refer to? Architecture of what?

2. Seminar - read managing SSD

- a. What is the effect on security of selecting a SD methodology?
- b. What are the main factors to consider?
- c. Agree within your team which methodology you will select for the project

3. (DM)LC2 - Programming languages & Design

- a. History of Prog languages
- b. Types of languages (declarative, Obj, etc) & Security implications inc abstraction, encapsulation, inheritance
- c. Examples of typical security issues (buffer overflows, unmanaged code, etc)
- d. Design & prog languages
- e. Compilers & libraries: considerations
- f. Secure sw patterns ?
- g. Types of applications
- h. The cost of security
- i. LESP
- j. Read ch4 of course text

Commented [PC3]: In what way is this being considered from the security perspective?

4. Seminar

- a. Read Cifuentes & Bierman (2012)
 - i. What are key factors in choosing a sec prg lang?
- b. Read the whitesource article
 - i. Does that indicate any change in the most sec prg languages?
 - ii. What factors have led to any changes
- c. What effect does the choice of architecture & arch patterns have on PL selection?
- d. For this module we will use Python as the selected PL
 - i. does that have any effect on the selection of methodology or architecture?
 - ii. What are the security Pros & cons of Python

5. (CP)LC3 - Testing (Glenford J Myers *The Art of Software Testing* (1979) thoughtworks; fowler test pyramid.)

- a. Why & How to test
- b. Types of testing
 - i. Unit tests
 - ii. Integration tests
 - iii. Contract/ API tests
 - iv. UI tests
 - v. E2E tests
 - vi. UAT
 - vii. SAST & DAST (static & dynamic app sec testers)
- c. Automated testing, code & style checkers

6. Seminar

- a. Read larson (2018)
 - i. How could regex be used as part of a input verification solution
- b. Read Zhang et al (2017)

- i. How would a static/ lint checker help validate your application?
 - c. Exercise: use pyXX to check your code - what errors did it find? How can these be addressed?
- 7. (DM)LC4 - Operations & Operating Systems
 - a. History of OS
 - b. OS Design & Architecture challenges: Usability vs. Security
 - c. Security models: least privilege, open design, fail-safe defaults, separation of privilege, and the least common mechanism
 - d. Operations & Deployment considerations
 - e. Security protocols to support distributed computing (inc. IPSec), SSL
 - f. Read ops chapter of course text
- 8. Seminar
 - a. deployment & env issues
 - b. Refactoring the application & using API (inc reading on why & howto)
- 9. (CP)LC5 - Microarchitectures, containers & distributed computing
 - a. What is distributed computing? History from Corba thru SOA and Microservices; fallacies;
 - b. Monoliths vs. Microservices
 - c. Virtualisation: Pros & Cons
 - i. Cloud
 - d. Containers vs Virtualisation
 - e. API Security considerations
 - f. Clustering & orchestration
- 10. Seminar
 - a. Fritzsche et al(2018) - refactoring
 - b. Exercise: refactoring the applications for dist computing
- 11. (DM)LC6 - Future Trends
 - a. DevSecOps
 - b. Automation
 - c. Secure Methodologies
 - d. Blockchain
 - e. ML
- 12. Discussion/ debate: what is best monolith or Microservices
 - a. Reading torvalds vs tanenbaum;
 - b. Newman (2019)

Commented [PC4]: I don't understand why we need to go into OSs as part of this module

Commented [PC5]: "ideal place to talk about secure protocols"

Formatted

The particular security concerns of specific applications? Which applications are vulnerable to which types of security attacks, and how does this impact the way they are developed?

Does LESP matter within the context of this module? The profile of people developing software and the subsequent potential security risks. Or even, the profile of people who are attacking software and the way it should subsequently be developed in response.

Secure cloud

Secure protocols – IPSec

Security problems associated with particular protocols

What is the cost of security? How to evaluate the cost-benefit impact? Cost of testing, cost of more design

